

URL Parsing Issue in [huggingface/transformers](#)

✓ Valid

Reported on Mar 20th 2025

- **Repository:** [Hugging Face Transformers](#)
- **File:** `image_utils.py`
- **Line:** 834

Code Snippet:

```
if video.startswith("https://www.youtube.com") or video.startswith("http://www.yout
```

Vulnerability Description:

The current implementation checks if a `video` URL starts with `"https://www.youtube.com"` or `"http://www.youtube.com"`. However, this method is **insecure** because it does not correctly validate URLs and can be **bypassed using URL username injection**.

Exploitation Example:

An attacker can craft a malicious URL that bypasses the validation check while redirecting users to an attacker-controlled domain:

```
https://youtube.com@evil.com/evil.exe
```

In this case:

- The URL **passes** the `startswith("https://www.youtube.com")` check.
- However, **it actually resolves to** `evil.com`, **not YouTube**.
- This can be exploited for **phishing, malware downloads, or credential theft**.

Recommended Fix:

Use proper URL parsing and validation instead of `startswith()`. Python's `urllib.parse` can help ensure the URL belongs to YouTube's domain:

```
from urllib.parse import urlparse

def is_youtube_url(video: str) -> bool:
    parsed_url = urlparse(video)
    return parsed_url.netloc in ["www.youtube.com", "youtube.com"]
```

```
# Usage
if is_youtube_url(video):
    # Safe processing
```

Why this is safer:

- `urlparse()` correctly extracts the domain (`netloc`), preventing username injection attacks.
- It ensures that only YouTube domains are allowed, rejecting malformed URLs.

Impact

Security Impact:

- **Phishing Attacks:** Attackers can trick users into believing they are visiting YouTube while actually landing on a malicious site.
- **Malware Distribution:** The attacker-controlled URL can serve malicious files.
- **Data Exfiltration:** If the application processes or fetches the URL content, it may expose sensitive data to an attacker.

⚙️ We are processing your report and will contact the **huggingface/transformers** team within 24 hours. 10 months ago



✎ Michelle Habonneau modified the Severity from Medium (5.3) to Low (3.5) 9 months ago



Michelle Habonneau commented 9 months ago

Maintainer

Hi, Thanks for submitting this report. We'll take a look at updating with a fix real soon and close this report once done. Thanks again



A **huggingface/transformers** maintainer has acknowledged this report 9 months ago



The scheduled publication date was automatically extended from 18th Jun 2025 to 25th Jun 2025 due to the maintainers acknowledgement of the report 9 months ago



The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



Michelle Habonneau validated this vulnerability 9 months ago



aydinnyunus has been awarded the disclosure bounty ✓



The fix bounty is now up for grabs



The researcher's credibility has increased: +7



Yunus AYDIN commented 9 months ago

Researcher

Thank you. Fix is released can we share the report as public ?

✉ We have notified the **huggingface/transformers** maintainers about this report in their weekly follow-up 8 months ago

[Sign in](#) to join this conversation

CVE
CVE-2025-3777
Published

Vulnerability Type
CWE-20: Improper Input Validation

Severity
Low (3.5)

Attack vector	Network
Attack complexity	Low
Privileges required	Low
User interaction	Required
Scope	Unchanged
Confidentiality	Low
Integrity	None
Availability	None

[Open in visual CVSS calculator](#)

Registry
Other

Affected Version
<= 4.49.0

Visibility
Public

Status
Fixed

Disclosure Bounty
\$20

Fix Bounty
\$5

Found by



Yunus AYDIN

@aydinnyunus

MIDDLEWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)